

Protection Mémoire, ASR et Credential Guard (Mode Expert)

Objectif : Blinder le processus LSASS contre l'extraction de mots de passe, déployer une défense comportementale (ASR) en ligne de commande, configurer l'Hyperviseur Windows (VBS), et valider l'efficacité des défenses via un "Crash-Test".

Prérequis (Validation du moteur Defender)

Les règles de Réduction de la Surface d'Attaque (ASR) ne fonctionnent **QUE** si l'antivirus Microsoft Defender est le moteur actif du système. S'il est désactivé, l'ASR sera inopérant.

1. Ouvrez une console **PowerShell en tant qu'Administrateur**.
 - Vérifiez que le service anti-malware tourne correctement :
`Get-MpComputerStatus | Select-Object AMServiceEnabled, AntivirusEnabled, BehaviorMonitorEnabled`
2. (Toutes les valeurs doivent retourner **True**. Si c'est le cas, vous pouvez continuer).

Protection Logicielle (LSA Protection / PPL)

Nous allons ordonner au noyau Windows (Ring 0) de rejeter toute tentative de lecture de la RAM de **lsass.exe** par des processus non signés par Microsoft.

- Toujours dans votre console PowerShell, forcez la création de la clé de registre activant le **RunAsPPL** :
`Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "RunAsPPL" -Value 1 -Type DWord -Force`
1.
 - Validez que la clé a bien été injectée :
`Get-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "RunAsPPL"`
 2. (Note : Cette protection logicielle ne sera effective qu'au prochain redémarrage. Ne redémarrez pas tout de suite, nous le ferons à la fin).

Déploiement Comportemental (ASR) via PowerShell

Plutôt que d'utiliser la GPO, un architecte moderne déploie ses règles ASR via des scripts. Nous allons déployer deux règles critiques de l'ANSSI en **Mode Audit** (Valeur = 2) pour ne pas casser la production.

- GUID pour "Bloquer le vol d'identifiants dans LSASS" :
9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2
- GUID pour "Bloquer la création de processus enfants par Office" :
d4f940ab-401b-4efc-aadc-ad5f3c50688a
 - Exécutez cette commande PowerShell pour injecter ces deux règles en Mode Audit (**AuditMode**) :

```
Set-MpPreference -AttackSurfaceReductionRules_Iids  
9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2,  
d4f940ab-401b-4efc-aadc-ad5f3c50688a  
-AttackSurfaceReductionRules_Actions AuditMode, AuditMode
```

1.

- **Validation d'Audit (Le script de l'architecte)** : L'interface PowerShell par défaut n'est pas très lisible pour vérifier l'ASR. Exécutez ce script de 3 lignes pour afficher proprement vos règles actives :

```
$ASR = Get-MpPreference  
$ASR.AttackSurfaceReductionRules_Iids | ForEach-Object -Begin { $i=0 }  
-Process {  
    [PSCustomObject]@{ GUID = $_.GUID ; Action =  
        $ASR.AttackSurfaceReductionRules_Actions[$i] }; $i++  
}
```

2. (Vous devez voir vos deux GUID avec l'Action '2', qui correspond au Mode Audit).

Déploiement de Credential Guard (GPO)

Nous allons maintenant demander à Windows de s'isoler lui-même en créant un mini-hyperviseur (VTL 1) pour cacher les hashes NTLM. Comme c'est une configuration lourde, nous utiliserons les Stratégies de Groupe (GPO).

1. Ouvrez la **Gestion de stratégie de groupe** (**gpmc.msc**).
2. Faites un clic droit sur l'Unité d'Organisation **Domain Controllers** > **Créer un objet GPO...**
3. Nommez-la **GPO-SEC-Tier0-CredentialGuard** et **Modifiez-la**.
4. Naviguez précisément dans ce chemin : **Configuration ordinateur** > **Stratégies** > **Modèles d'administration** > **Système** > **Device Guard**
5. Double-cliquez sur le paramètre **Activer la sécurité basée sur la virtualisation**.
6. Cochez **Activé** et configurez les options critiques suivantes (Exigences ANSSI) :
 - **Sélectionner le niveau de sécurité de la plateforme** : **Démarrage sécurisé (Secure Boot)**

- **Configuration Credential Guard** : *Activé avec le verrouillage UEFI* (Empêche un pirate, même administrateur, de désactiver la protection à distance sans accès physique au BIOS).
 - **Configuration de la protection du code (HVCI)** : *Non configuré* (Pour éviter des problèmes de compatibilité de pilotes sur ce lab).
7. Validez (OK) et fermez l'éditeur.

Application, Redémarrage et Preuves (WMI)

5.1 Redémarrage (Application du Ring -1)

Toutes les protections que nous avons configurées nécessitent un redémarrage complet de l'OS.

- Forcez la GPO puis redémarrez :
gpupdate /force
 - Restart-Computer -Force
- 1.

5.2 Preuve d'Audit Matériel (WMI)

Reconnectez-vous avec *FORMATION\Administrateur*. L'auditeur ne se fie jamais à la GPO, il interroge le processeur via WMI pour savoir si le VTL1 tourne vraiment.

1. Ouvrez **PowerShell en tant qu'Administrateur**.
 - Interrogez la classe WMI de Device Guard :
Get-CimInstance -ClassName Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard | Format-List SecurityServicesConfigured, SecurityServicesRunning
- 2.

LECTURE DES RÉSULTATS :

- **SecurityServicesConfigured** : Doit contenir *1* (Credential Guard). Cela prouve que votre GPO est parfaite.
- **SecurityServicesRunning** :
 - Si vous obtenez *1* : Félicitations, l'OS est inviolable, la VM supporte la virtualisation imbriquée.
 - Si c'est vide (ou 0) : Cela signifie simplement que la plateforme de Lab (VMware hôte) ne permet pas à votre VM d'accéder aux instructions processeur Intel VT-x.

Le Crash-Test (Validation SOC et Red Team)

Maintenant que le serveur est blindé, nous allons prouver que nos défenses fonctionnent en essayant de les attaquer.

6.1 Test de la protection LSASS (PPL)

Même en tant qu'Administrateur du Domaine, le noyau devrait désormais nous empêcher de lire la RAM de LSASS.

1. Faites un clic droit sur la barre des tâches et ouvrez le **Gestionnaire des tâches**.
2. Allez dans l'onglet **Détails**.
3. Cherchez le processus **lsass.exe**.
4. Faites un clic droit dessus > **Créer un fichier de vidage** (Create dump file).
 - **Résultat attendu** : Windows affiche un message d'erreur strict : **"Accès Refusé" (Access Denied)**. Le noyau vient de bloquer l'administrateur ! Le Pass-the-Hash en mémoire vient de devenir quasiment impossible.

6.2 Test et Traçabilité ASR (L'investigation SOC)

Nous avons configuré l'ASR en mode Audit. Que se passe-t-il si un programme suspect tente de lire LSASS ? Defender va générer un journal critique.

1. Ouvrez l'**Observateur d'événements** (**eventvwr.msc**).
2. Déroulez précisément cette arborescence (C'est ici que le SOC surveille le parc) :
 - **Journaux des applications et des services > Microsoft > Windows > Windows Defender > Operational**.
3. Cherchez dans ce journal s'il y a un événement **ID 1121** (ou **1122** en mode blocage).
 - L'ID 1121 signifie : "La règle de réduction de la surface d'attaque a audité une action".
 - Si vous n'en voyez pas, c'est normal sur un lab vierge. Mais dans la vraie vie, toute tentative de lancement de Mimikatz ou d'injection par un attaquant générera une alerte de type 1121 ici, alertant immédiatement le SOC avant même que la compromission ne soit totale.